

Segurança de Sistemas

Apresentação –Padding Oracle Attack

Prof. Edson Ifarraguirre Moreno

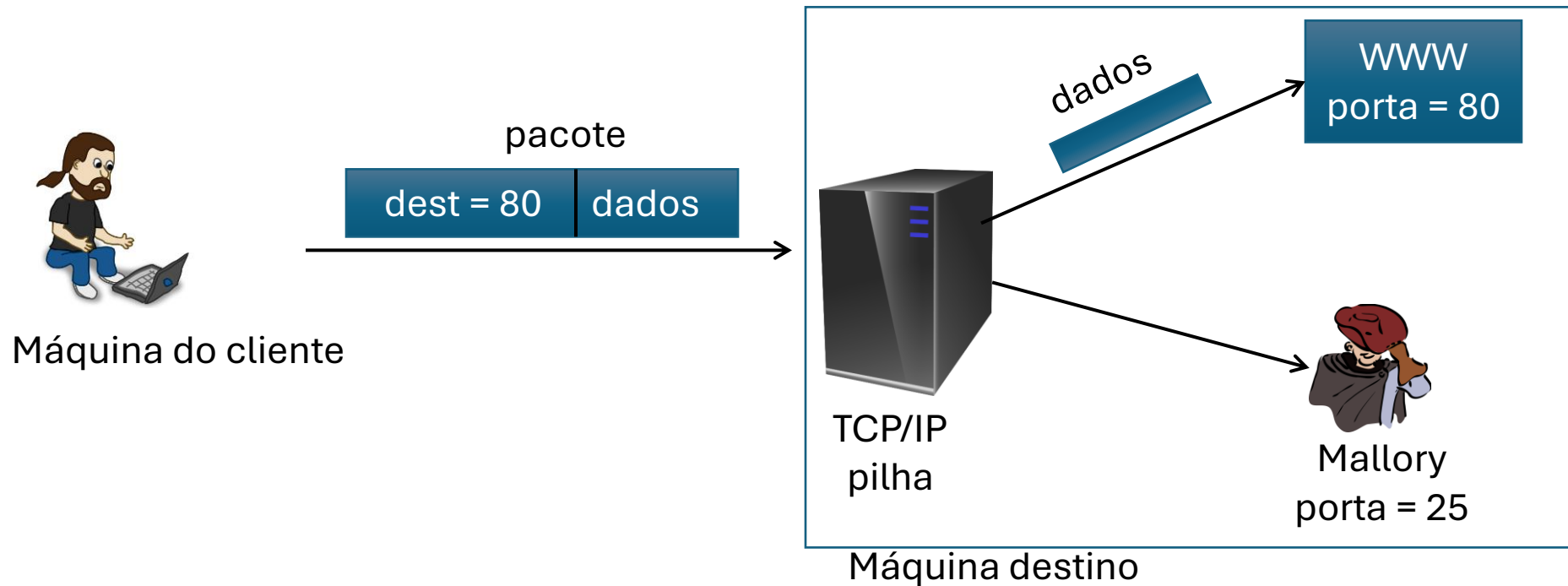
Elaborado a partir do material gerado pelo prof. Avelino Zorzo

Criptografia autenticada

- Em segurança no mundo real,
 - Criptografia geralmente é feita em um modo autenticado
 - Produz um MAC como parte do processo de criptografia
 - Provê
 - Confidencialidade (privacidade)
 - Integridade (autenticidade)
- Exemplos de criptografia autenticada
 - Cifrar com CBC + CBC-MAC
 - Cifrar com CTR + CBC-MAC (IEEE802.11i)

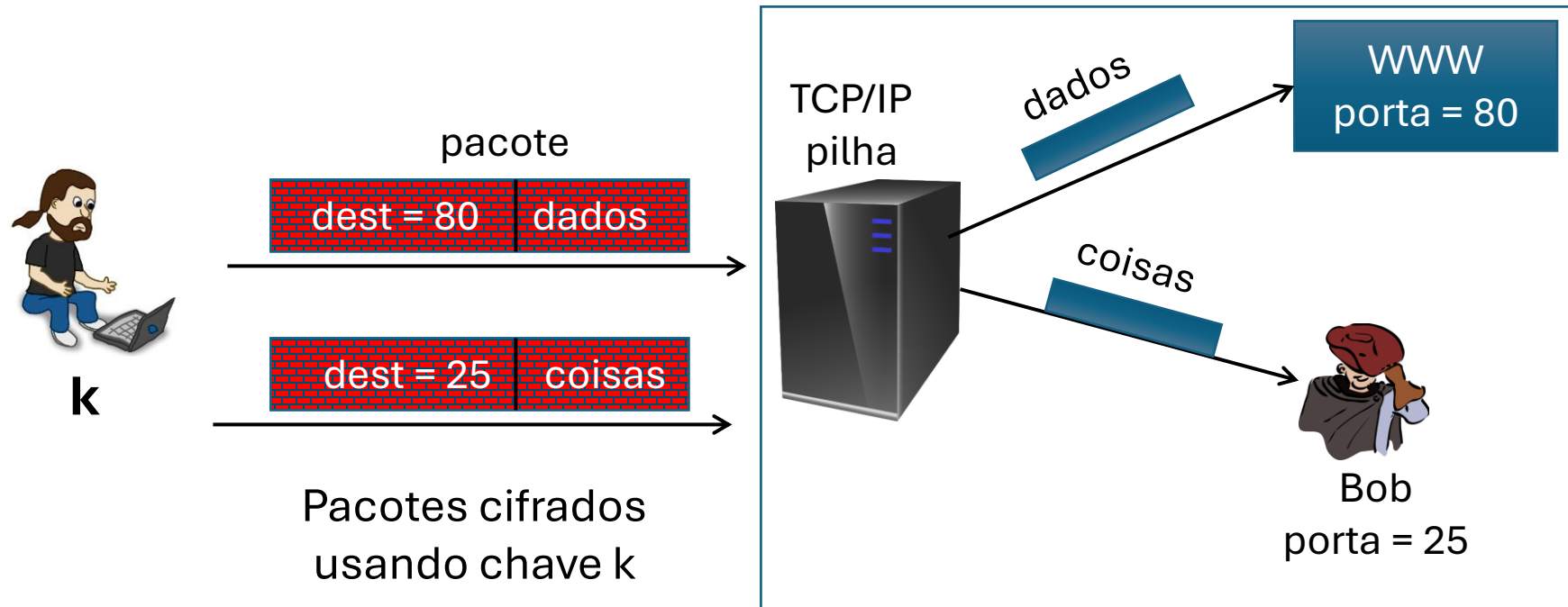
Relembrando: Exemplo de ataque

TCP/IP: (de maneira abstrata)



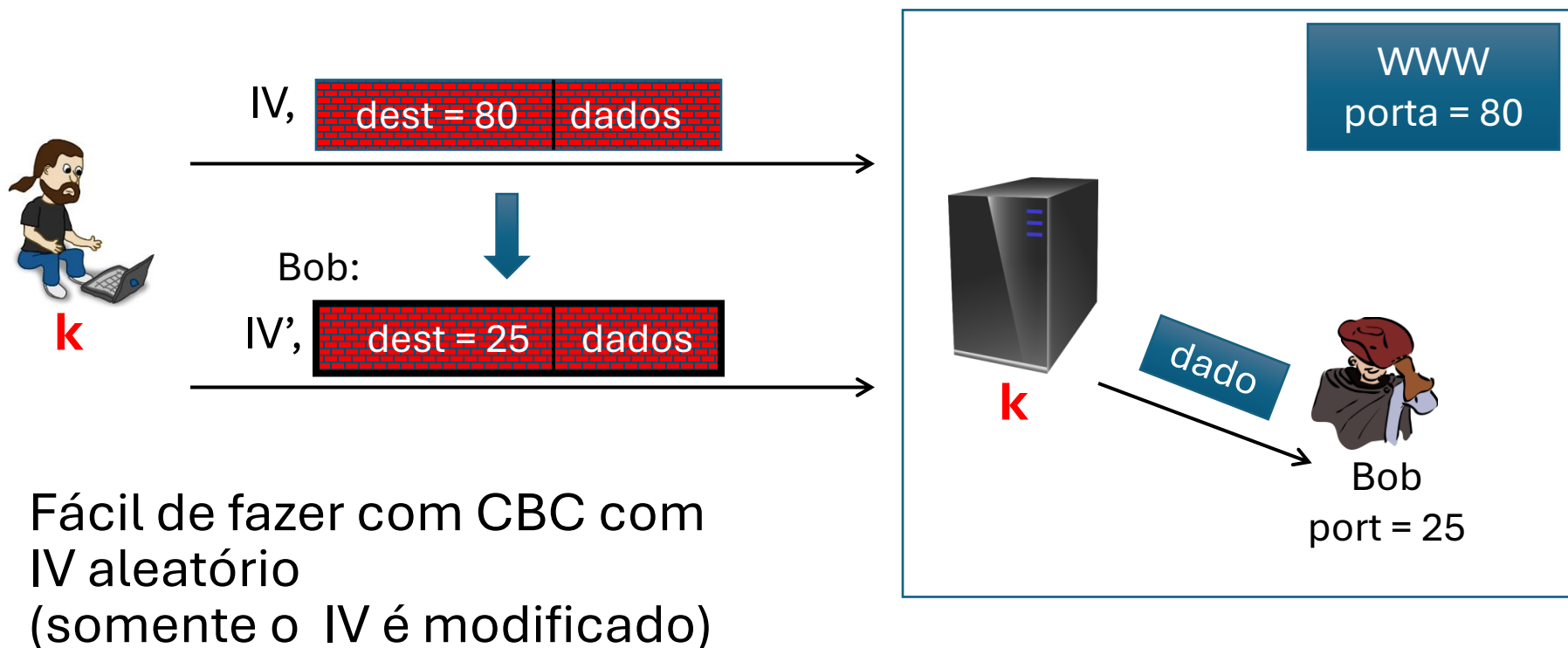
Exemplo de ataque

IPsec: (highly abstracted)



Lendo dados de outros

- Note: atacante decifra qualquer texto cifrado que inicia com “dest=25”



Pergunta

- Criptografia é feita com CBC usando IV aleatório.



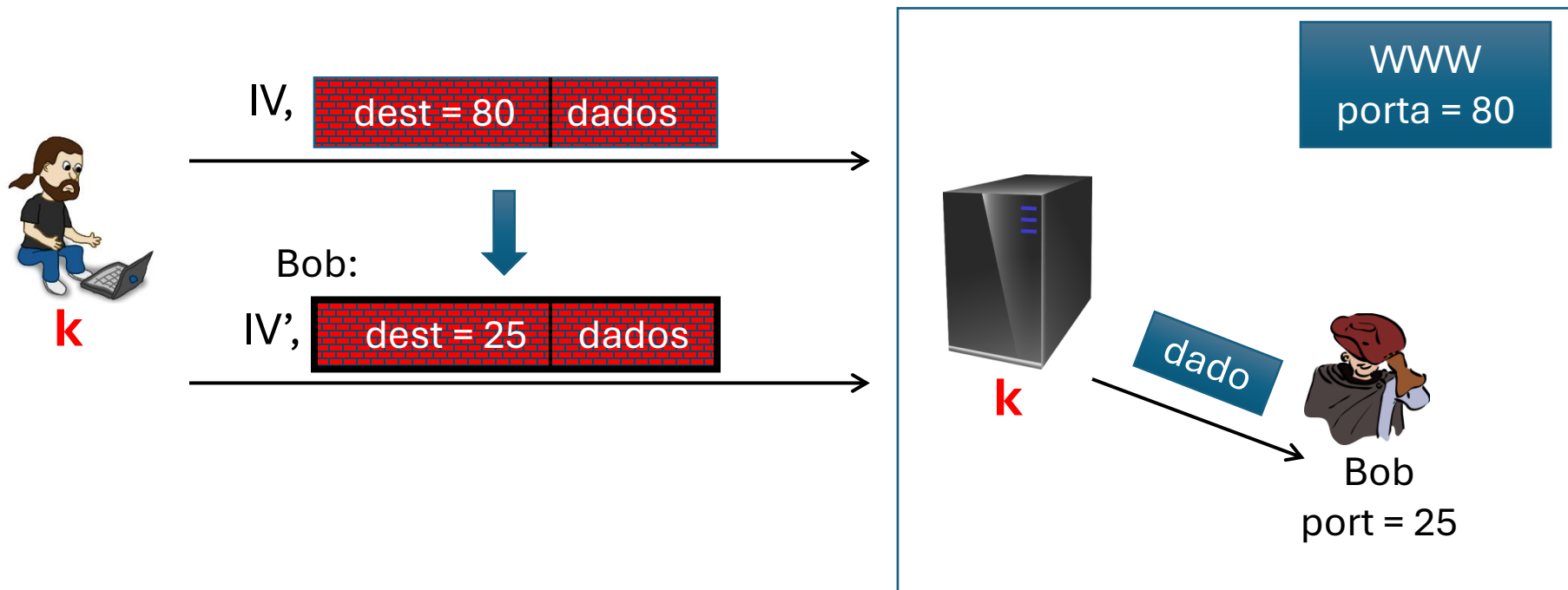
- Qual deve ser o IV' ?

- $IV' = IV \oplus (...25...)$
- $IV' = IV \oplus (...80...)$
- $IV' = IV \oplus (...80...) \oplus (...25...)$
- Não pode ser feito

$$m[0] = D(k, c[0]) \oplus IV = \text{"dest=80..."}$$

Característica deste ataque

- O dado original (ou parte dele) é conhecido
 - O ataque é feito de forma “cirurgica” para mudar a interpretação da informação



Padding Oracle Attack

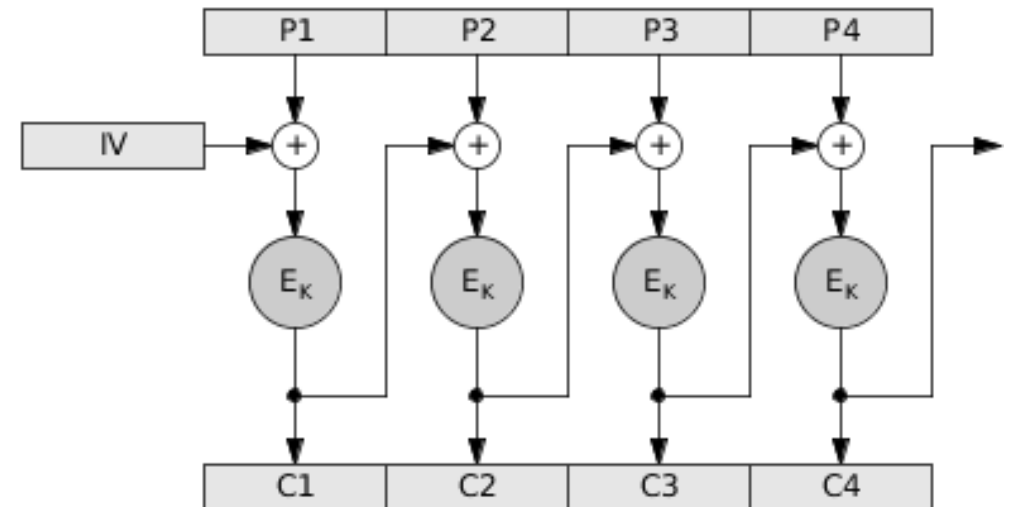
- Padding Oracle Attack também é um ataque de criptografia
 - Usa a validação do *padding* de uma mensagem criptográfica para decifrar o texto cifrado
 - Padding (relembrar é viver)
 - Recurso adicionado ao final das mensagens para garantir o tamanho dos blocos
 - São adicionados tantos bytes quantos faltam para completar um bloco
 - Cada byte adicionado representa o número de bytes que faltam

BLOCK #1									BLOCK #2							
	1	2	3	4	5	6	7	8	1	2	3	4	5	6	7	8
Ex 1	F	I	G													
Ex 1 (Padded)	F	I	G	0x05	0x05	0x05	0x05	0x05								
Ex 2	B	A	N	A	N	A										
Ex 2 (Padded)	B	A	N	A	N	A	0x02	0x02								
Ex 3	A	V	O	C	A	D	O									
Ex 3 (Padded)	A	V	O	C	A	D	O	0x01								

- O ataque requer um "*padding oracle*"
 - Algo tem de retornar se a mensagem foi elaborada com o *padd* adequado ou não

Padding Oracle Attack

- Padding Oracle Attack é um ataque de criptografia
- Ataque realizado por força bruta
 - Decifragem é explorada à exaustão
 - Combinação feita byte a byte
 - A chave é desconhecida
- CBC – Cipher Block Chain
 - Texto cifrado é quebrado em blocos
 - Blocos tem tamanho fixo e conhecido
 - Um bloco tem relação direta com o anterior
 - O primeiro bloco é o vetor de inicialização
 - Gerado aleatoriamente



Padding Oracle Attack

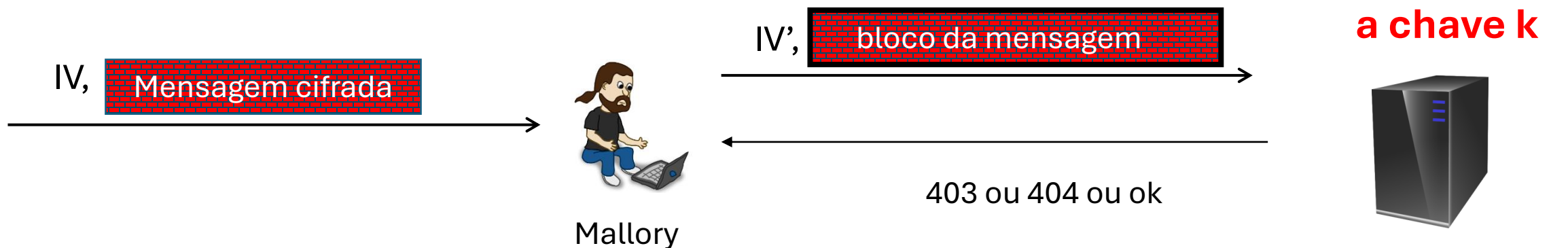
- Ao receber uma mensagem cifrada
 - Sistema realiza um conjunto de passos para decifrar
- Passos “simplificados”
 - [PASSO 1] Todo o texto cifrado é convertido em texto claro
 - [PASSO 2] O *padding* é removido
- Durante a etapa de remoção de *padding*
 - É comum a validação do *padding*
 - Se o *padding* é inválido então é comum “disparar” um evento
 - Pode surgir uma vulnerabilidade – Torna-se suscetível a *padding oracle attack*
 - Comportamento detectável
 - Um erro
 - A abstenção de um retorno esperado
 - Uma demora na resposta

Padding Oracle Attack

- O que é sábio para a realização do ataque
 - As características da mensagem cifrada
 - Cada bloco possui 16bytes
 - O vetor de inicialização (IV)
 - Também possui 16 bytes
 - É o primeiro bloco da mensagem
- O objetivo
 - Decifrar a mensagem criptografada

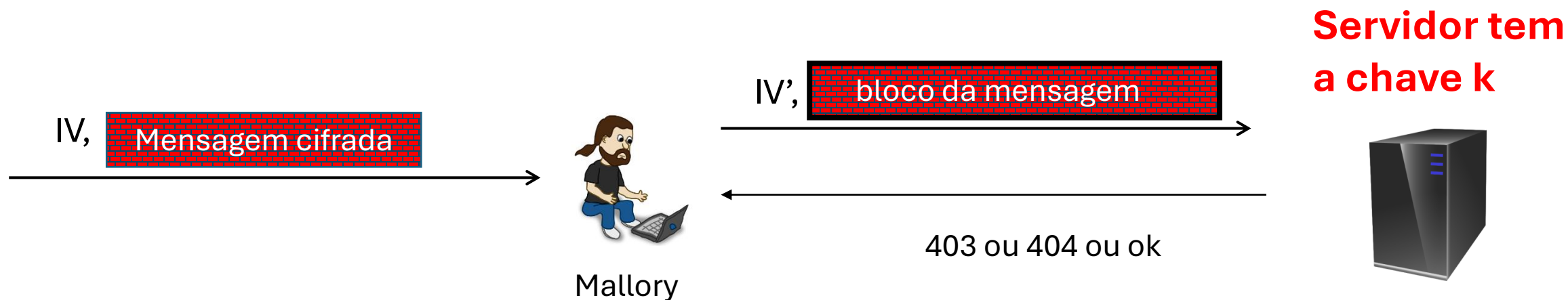
Padding oracle attack

- HTTPS
 - Antigamente era suscetível a ataques do tipo *padding oracle*
 - Mensagem enviada de forma cifrada tinha retorno “interpretável”
 - **403: padding está errado**
 - **404: padding está correto, mas tem outro erro.**



Padding oracle attack

- Exemplo
 - <http://crypto-class.appspot.com/po?er=f20bdba6ff29eed7b046d1df9fb7000058b1ffb4210a580f748b4ac714c001bd4a61044426fb515dad3f21f18aa577c0bdf302936266926ff37dbf7035d5eeb4>



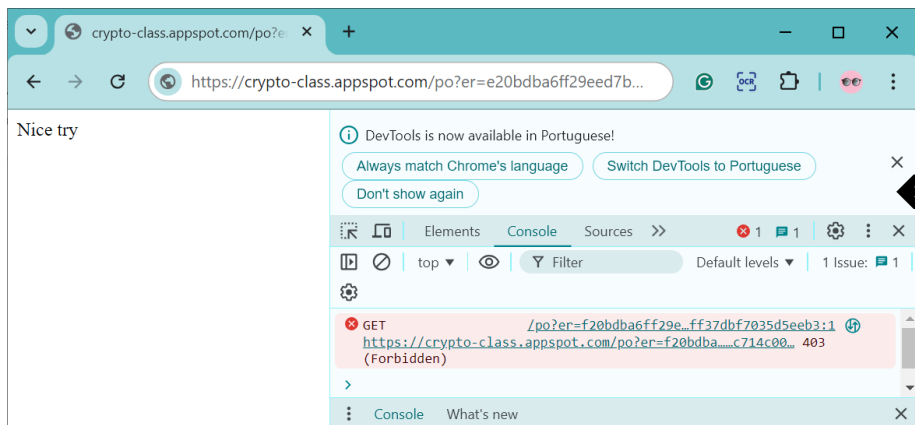
<http://crypto-class.appspot.com/po?er=f20bdba6ff29eed7b046d1df9fb7000058b1ffb4210a580f748b4ac714c001bd4a61044426fb515dad3f21f18aa577c0bdf302936266926ff37dbf7035d5eeb4>

IV	bloco 1	bloco 2	bloco 3
----	---------	---------	---------

Mensagem cifrada

Padding oracle attack

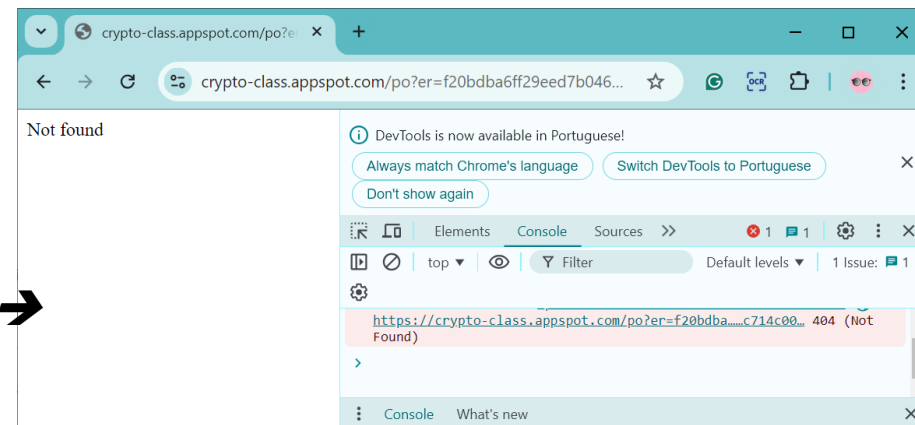
- Exemplo
 - <http://crypto-class.appspot.com/po?er=f20bdba6ff29eed7b046d1df9fb7000058b1ffb4210a580f748b4ac714c001bd4a61044426fb515dad3f21f18aa577c0bdf302936266926ff37dbf7035d5eeb4>



← Padding Oracle →

← Erro de padding

Outro Erro (e.g. autenticação) →



<http://crypto-class.appspot.com/po?er=f20bdba6ff29eed7b046d1df9fb7000058b1ffb4210a580f748b4ac714c001bd4a61044426fb515dad3f21f18aa577c0bdf302936266926ff37dbf7035d5eeb4>

IV

bloco 1

bloco 2

bloco 3

Mensagem cifrada

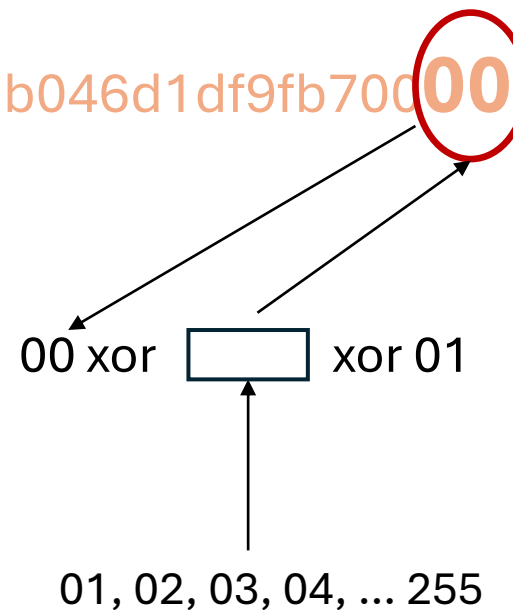
Demonstração prática de ataque

Padding oracle attack

- Passos para a condução do ataque:
 - Quebrar a mensagem entre IV e blocos de 128 bits (16bytes)
 - Alterar somente o IV
 - Assumiremos IV como o bloco “referência”
 - Descobrir caracter a caracter do bloco cifrado alterando cada byte do IV
 - Quando encontrar o caracter correto, o site retorna erro 404 (i.e. Padding está ok, mas mensagem não)
 - Salva o byte “escolhido” no IV e o *padding*
 - Começar supondo com 01 do byte menos significativo do bloco cifrado
 - Repetir o processo para o próximo caracter, agora com dois bytes em 02 (*padding 0202*)
 - Mantém os bytes já “descobertos”, aplicando xor com o novo padding
 - Quando receber a mensagem 404 acertou o segundo caracter
 - Repita até descobrir todos os caracteres do bloco
- Para o próximo bloco
 - O primeiro bloco cifrado vira IV e o Segundo vira o primeiro bloco
- Repetir os passos anteriores

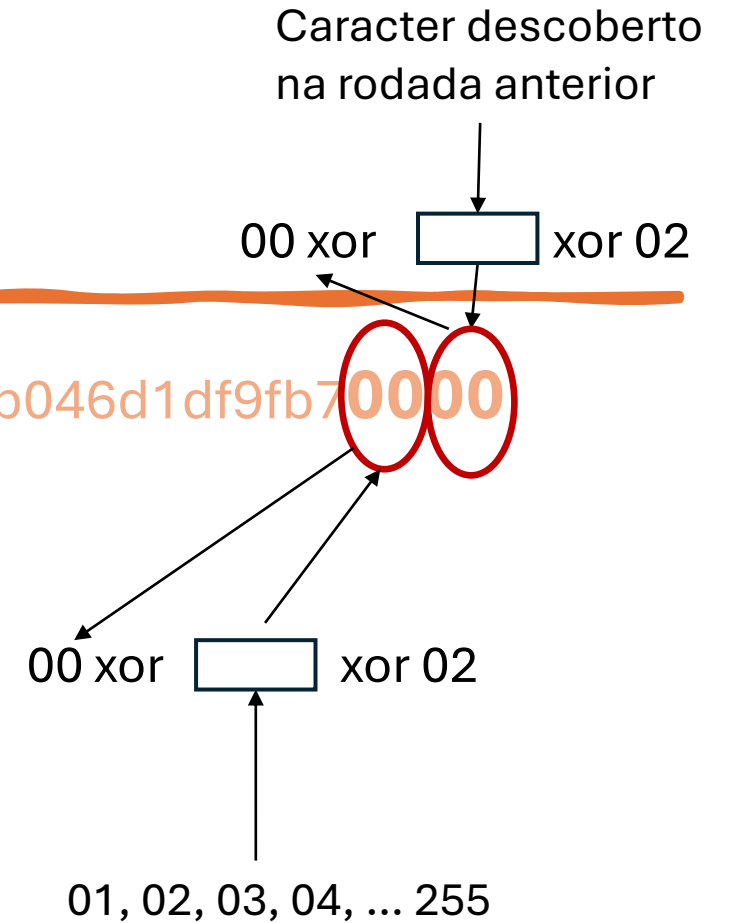
Padding oracle attack

- <http://crypto-class.appspot.com/po?er=f20bdba6ff29eed7b046d1df9fb7000000>
- 58b1ffb4210a580f748b4ac714c001bd
- E o próximo character?
- URL ORIGINAL:
 - <http://crypto-class.appspot.com/po?er=f20bdba6ff29eed7b046d1df9fb7000000> → IV de agora
 - 58b1ffb4210a580f748b4ac714c001bd → Bloco a ser decifrado
 - 4a61044426fb515dad3f21f18aa577c0
 - bdf302936266926ff37dbf7035d5eeb4



Padding oracle attack

- <http://crypto-class.appspot.com/po?er=f20bdba6ff29eed7b046d1df9fb70000>
- 58b1ffb4210a580f748b4ac714c001bd
- E o próximo character?
- URL ORIGINAL:
 - <http://crypto-class.appspot.com/po?er=f20bdba6ff29eed7b046d1df9fb70000> → IV de agora
 - 58b1ffb4210a580f748b4ac714c001bd → Bloco a ser decifrado
 - 4a61044426fb515dad3f21f18aa577c0
 - bdf302936266926ff37dbf7035d5eeb4



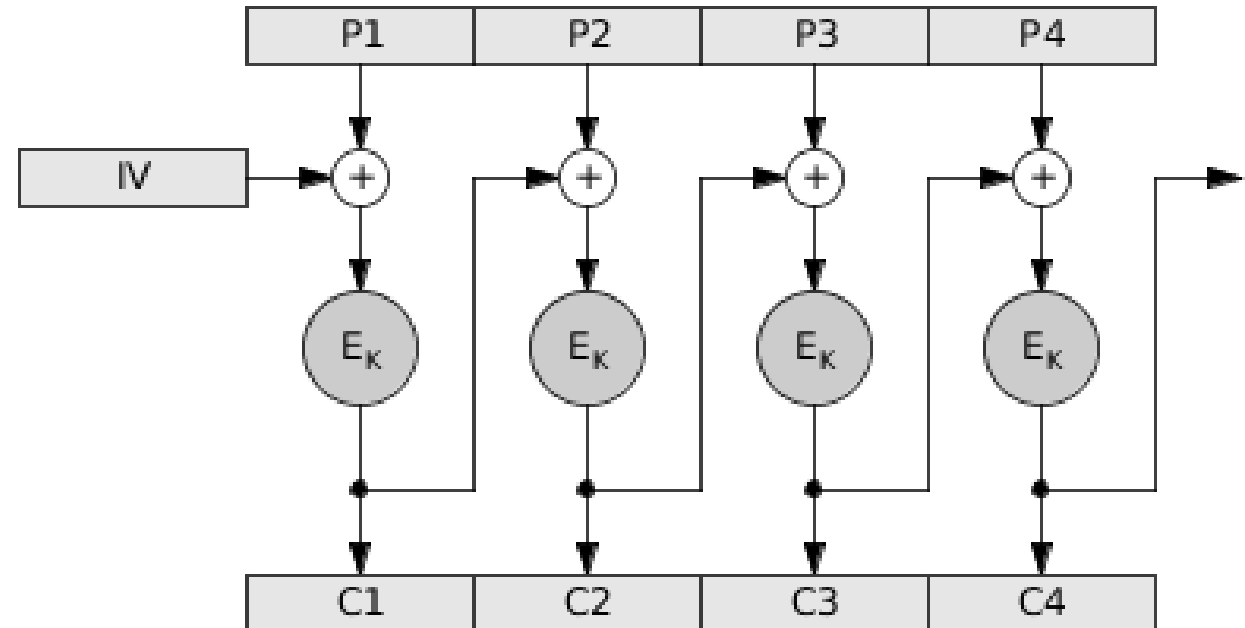
Padding oracle attack

- <http://crypto-class.appspot.com/po?er=f20bdba6ff29eed7b046d1df9fb70000>
- 58b1ffb4210a580f748b4ac714c001bd
- 4a61044426fb515dad3f21f18aa577c0
- bdf302936266926ff37dbf7035d5eeb4

Próxima rodada
este bloco vira IV

Bloco a decifrar

- Repete para cada bloco



Padding oracle attack

- Problema já foi solucionado
 - Mensagem não tinha integridade
 - Atacante conseguia alterar mensagem e enviar para o servidor
 - Servidor mandava informação ao atacante
 - Informar erro 403 e 404 ajuda o atacante
- Solução adotada
 - Sempre gerar o mesmo erro
 - Problema
 - O tempo de resposta dá indícios do tipo de incoerência
 - Este mesmo ataque ainda poderia ser feito a partir do tempo que o servidor demora a responder
- Nova solução
 - Sempre levar o mesmo tempo de resposta do servidor

